Design Pattern Reference Monitor

Intento e definizione

Il Reference Monitor (noto anche come *Policy Enforcement Point*, cioè *Punto di Applicazione delle Policy*) è un design pattern pensato per la sicurezza, il cui intento è definire un'astrazione che intercetta tutte le richieste di accesso a una risorsa e ne controlla la conformità con le regole di autorizzazione definite.

Il **problema** è che se le regole di autorizzazione non vengono imposte rigorosamente, è come non averle. Cioè, gli utenti potrebbero accedere a dati o eseguire operazioni non consentite (ad esempio, leggere un file riservato). Inoltre, le autorizzazioni possono essere complesse (ad esempio, permettere la lettura solo di una parte di un file) e dipendere da vari attributi.

La **soluzione** proposta dal pattern è quella di inserire un componente (Monitor) che valuta ogni singola richiesta. Il processo è il seguente:

1. il Monitor intercetta la richiesta.
2. controlla se esistono autorizzazioni valide per quel soggetto e quella risorsa.
3. se conforme, inoltra la richiesta all'oggetto reale; altrimenti la blocca.

Il Reference Monitor realizza il principio di **complete mediation** (mediazione completa), garantendo che ogni accesso sia verificato. Molti sistemi reali infatti non rispettano questo principio (ad esempio, facendo un controllo solo all'inizio e dando poi per scontato che tutto sia sicuro).

Struttura e partecipanti

- **ProtectionObject**: è l'oggetto o la risorsa "sensibile" che deve essere protetta (es. un file, un database, un oggetto Book).
- **Subject**: chi richiede l'accesso al ProtectionObject (es. un utente autenticato, un processo o un client).
- **ReferenceMonitor**: il componente centrale che intercetta la richiesta e verifica le regole, cioè se esiste un'autorizzazione valida. Se esiste, allora inoltra la richiesta intercettata, altrimenti la blocca.
- **SetOfAuthorizationRules**: l'insieme delle regole di sicurezza/autorizzazione. Ad esempio:
  - ACL (Access Control List).
  - RBAC (Role-Based Access Control).
  - regole basate su attributi.
  - policy dinamiche.
- **Authorization**: la singola regola che definisce chi può fare cosa.
- **Request**: un elemento fondamentale di questo pattern. È l'oggetto che incapsula i **dettagli** della **richiesta** (chi fa la richiesta, quale risorsa vuole usare, quale operazione vuole fare, eventuali parametri, ecc.) fatta dal Subject. È modellata come una **Association Class** (classe di associazione) tra il Subject e il ReferenceMonitor, poiché contiene informazioni che non appartengono esclusivamente a nessuno dei due, ma qualificano la loro interazione.

Diagramma UML di sequenza

1. Il Subject invia una request(req) al ReferenceMonitor.
2. Il ReferenceMonitor consulta il SetOfAuthorizationRules (tramite exist(req)) per vedere se esiste un'autorizzazione valida.
3. Se l'autorizzazione esiste (true), il Monitor inoltra la chiamata request() al ProtectionObject; altrimenti l'accesso viene negato.

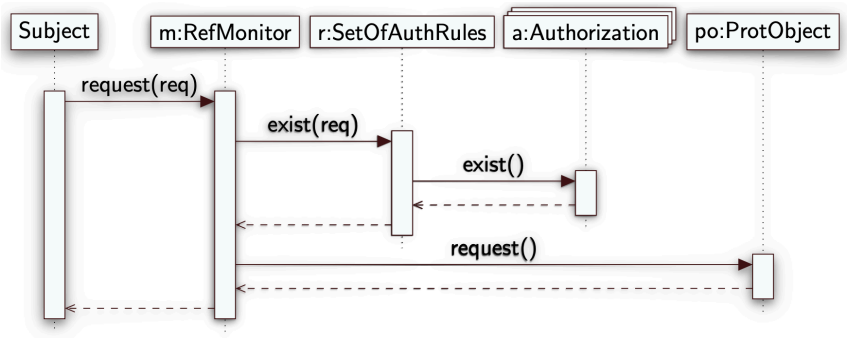
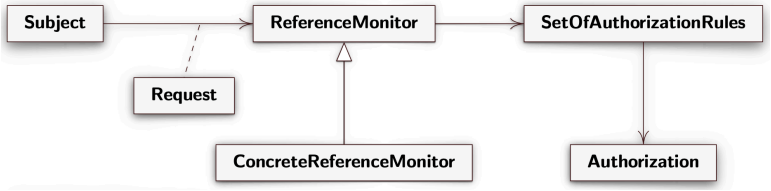


Diagramma UML delle classi



Implementazione e relazione con il Proxy

Mentre il Proxy è un design pattern strutturale (uno strumento tecnico), il Reference Monitor è un pattern architetturale di sicurezza (un principio di sicurezza).

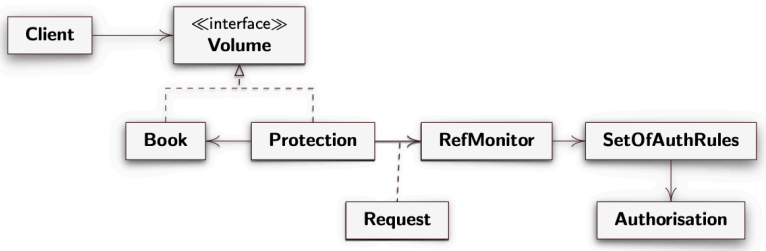
Per implementare concretamente l'intercettazione delle richieste si usa spesso il design pattern Proxy:

- si crea un Proxy per la risorsa da proteggere.
- si nasconde l'oggetto reale (ProtectionObject), magari rinominandolo o rendendolo inaccessibile direttamente, per assicurare che nessuno possa aggirare il Reference Monitor.

Un Proxy non è per sua natura un Reference Monitor, ma può diventarlo se si implementa in modo che intercetti tutte le richieste, non sia bypassabile e applichi sempre tutte le regole.

Esempio di Reference Monitor

- Book: è il ProtectionObject.
- Protection (Proxy): agisce parzialmente come ReferenceMonitor o lo invoca.
- Client: è il Subject
- RefMonitor: ha il ruolo di ReferenceMonitor.
- SetOfAuthRules: ha il ruolo di SetOfAuthorizationRules.
- Authorisation: ha il ruolo di Authorization



Conseguenze e prestazioni

L'uso del Reference Monitor comporta alcune considerazioni importanti:

- **Sicurezza**: se tutte le richieste sono intercettate, si ha la garanzia di imporre le regole di sicurezza.
- **Prestazioni**: controllare ogni singola richiesta può degradare le performance del sistema.
  - *Ottimizzazione*: si può scegliere di effettuare il controllo solo all'inizio (singolo controllo a monte) di un flusso di operazioni (ad esempio, al momento dell'apertura di un file) invece che a ogni singola lettura/scrittura, oppure memorizzare (tramite memoria cache) le decisioni prese in precedenza per evitare di rivalutare le regole costantemente. Ad esempio, si memorizza in cache che l'utente X può fare Y sull'oggetto Z, in modo da evitare di rivalutare la policy ogni volta. Nota però che se le policy cambiano dinamicamente, la cache pò diventare un rischio di sicurezza.